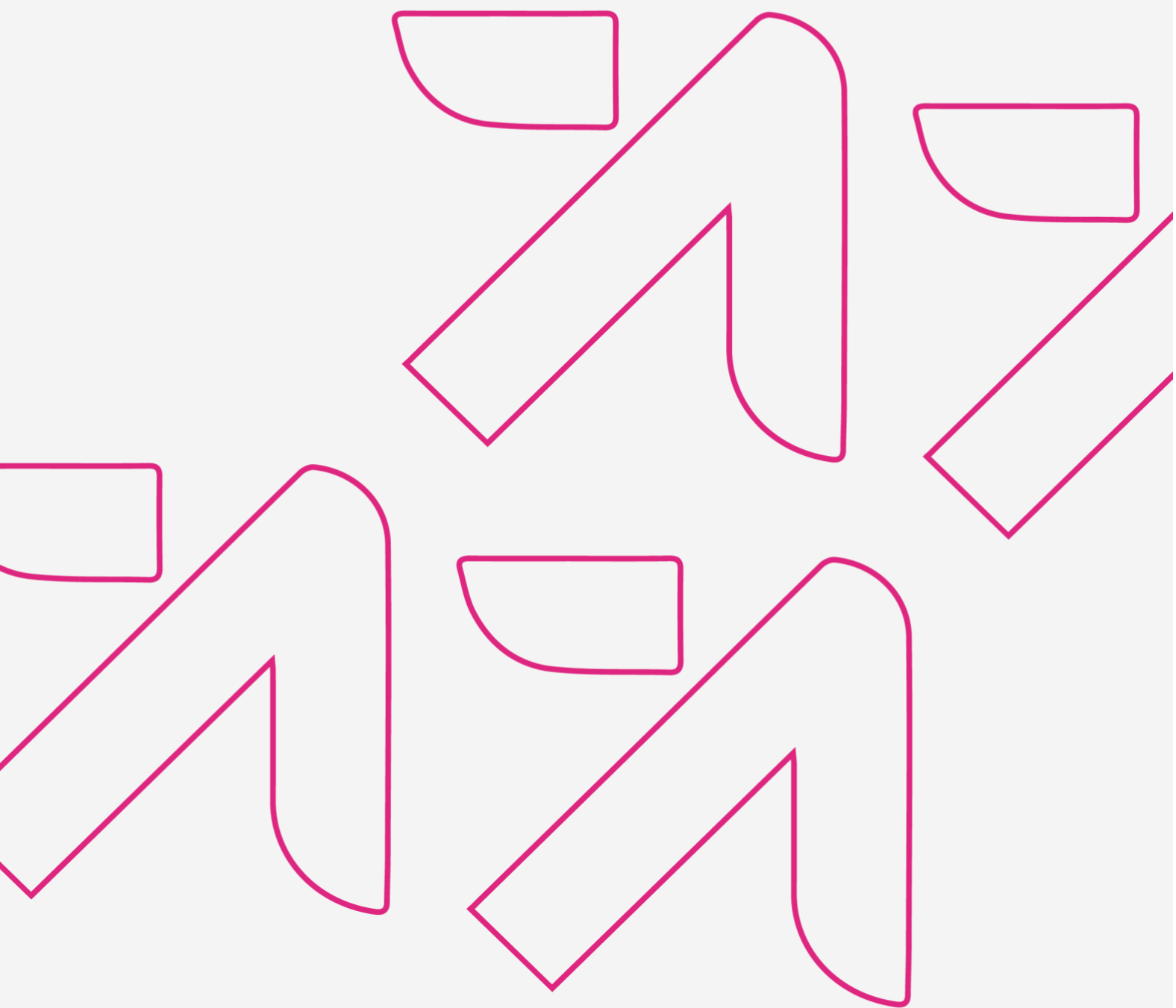




Máster de

Ciberseguridad Hacking Ético

[Módulo Incidentes de Ciberseguridad]

Curso académico 2026/2027 - Edición Presencial

Tema 6. Investigación y recogida de evidencias

Encaje en el curso 2026/2027: tema 6 del temario oficial, dentro del RA3. Se profundiza en el módulo de Análisis forense informático (5024); aquí interesa lo que hay que hacer, y lo que no, en las primeras horas de un incidente.

1. La evidencia digital

Una evidencia digital es cualquier información almacenada o transmitida en formato digital que puede servir para reconstruir lo ocurrido y, llegado el caso, probarlo ante un tercero: la dirección, una aseguradora, un cliente o un juez.

Es frágil por naturaleza: se altera con solo encender un equipo, desaparece al apagarlo y se copia sin dejar rastro. De ahí que el método importe tanto como la herramienta.

1.1. Normas y buenas prácticas

- **ISO/IEC 27037:** identificación, recolección, adquisición y preservación de evidencias digitales.
- **RFC 3227:** directrices para la recolección y el archivo de evidencias; de aquí sale el orden de volatilidad.
- **UNE 71505 y UNE 71506:** gestión de evidencias electrónicas y metodología de análisis forense, en España.

2. Principios fundamentales

2.1. Inmutabilidad

La evidencia original no se toca. Se trabaja siempre sobre copias, y el original se guarda protegido contra escritura.

2.2. Autenticidad e integridad

Hay que poder demostrar que la copia es idéntica al original y que no ha cambiado desde entonces. Se consigue con funciones hash (SHA-256): se calcula al adquirir y se vuelve a comprobar cada vez que se usa.

2.3. Trazabilidad: la cadena de custodia

Registro documental de todo lo que le ocurre a la evidencia desde que se recoge: quién, cuándo, dónde, qué hizo y a quién se la entregó. Un hueco en la cadena permite poner en duda todo lo demás.

2.4. Reproducibilidad

Otra persona, con los mismos datos y el mismo método, debe llegar al mismo resultado. Por eso se documenta cada paso y cada herramienta, con su versión.

2.5. Proporcionalidad y legalidad

Se recoge lo necesario para el caso, con autorización y respetando la privacidad. Revisar el buzón o el equipo de un empleado tiene límites legales: debe intervenir quien corresponda (dirección, asesoría jurídica, delegado de protección de datos).

3. El primer dilema: ¿apagar o no?

Apagar un equipo comprometido destruye la memoria RAM, que puede contener el malware, las claves de cifrado y las conexiones abiertas. Dejarlo encendido y conectado permite que el ataque continúe.

La pauta general: **aislar de la red sin apagar** (desconectar el cable, desactivar la wifi o aislar desde el EDR), capturar lo volátil y después decidir. La excepción es un cifrado en curso, donde detenerlo cuanto antes es prioritario.

4. Orden de volatilidad

Se recoge primero lo que antes desaparece:

1. Memoria RAM, procesos y conexiones de red activas.
2. Ficheros temporales y estado del sistema (usuarios conectados, tareas programadas).
3. Disco duro.
4. Registros enviados a sistemas remotos (SIEM, proxy, cortafuegos).
5. Copias de seguridad y soportes externos.

Ojo con el punto 4: los registros de servicios en la nube y de algunos dispositivos se sobrescriben en pocos días. Pedir su conservación es una de las primeras tareas.

5. Herramientas y técnicas

5.1. Adquisición de memoria

Herramientas como WinPmem, DumpIt o Magnet RAM Capture en Windows, y AVML o LiME en Linux. El volcado se analiza después con Volatility.

5.2. Clonación de discos

Se hace una imagen bit a bit, incluido el espacio no asignado, donde puede haber ficheros borrados.

- Se usa un bloqueador de escritura, físico o por software, para no alterar el original.
- Formatos habituales: imagen en bruto (.dd) y E01, que añade compresión y metadatos.

- Herramientas: FTK Imager, Guymager, dd y dc3dd.

```
# Identificar el dispositivo (¡comprobarlo dos veces!)
lsblk
# Hash del original antes de copiar
sudo sha256sum /dev/sdb
# Imagen bit a bit
sudo dd if=/dev/sdb of=evidencia01.dd bs=4M status=progress
# Hash de la imagen: debe coincidir con el del original
sha256sum evidencia01.dd
```

Cuidado con dd: confundir if (origen) con of (destino) sobrescribe la evidencia. Se revisa la orden antes de pulsar Intro. Para discos con sectores dañados se usan ddrescue o dc3dd, que además calculan el hash durante la copia.

5.3. Captura de tráfico de red

- tcpdump para capturar y Wireshark para analizar.
- La captura completa (PCAP) ocupa mucho; a menudo se guardan solo flujos (quién habló con quién, cuándo y cuánto).

```
# Capturar todo el tráfico de un equipo sospechoso a un fichero
sudo tcpdump -i eth0 host 10.10.10.25 -w captura01.pcap
```

5.4. Registros

- Windows: registros de eventos (Seguridad, Sistema, PowerShell, Sysmon si está instalado).
- Linux: /var/log/ y journalctl.
- Aplicaciones, servidores web, proxy, cortafuegos, VPN, correo y servicios en la nube.

Se exportan sin modificar, se anota la zona horaria de cada fuente y se calcula su hash.

5.5. Triage rápido

Cuando hay muchos equipos y poco tiempo, en lugar de imágenes completas se recogen solo los artefactos clave de cada uno con herramientas como KAPE o Velociraptor.

6. Cadena de custodia en la práctica

Cada evidencia lleva una ficha como esta:

Campo	Ejemplo
Identificador	EV-2026-014-01
Descripción	Disco SSD de 512 GB, portátil de administración, n.º de serie...
Recogida	Fecha, hora, lugar y persona que la recoge
Método y herramienta	Imagen con FTK Imager 4.x mediante bloqueador de escritura
Hash	SHA-256 del original y de la copia
Almacenamiento	Armario cerrado, sala 2; acceso restringido

Trasposos	Fecha, quién entrega, quién recibe, motivo y firmas
-----------	---

Buenas costumbres: fotografiar el equipo y las conexiones antes de tocar nada, precintar y etiquetar, y anotar la hora del sistema junto a la hora real.

7. Preservación y análisis

- Dos copias como mínimo: una de trabajo y otra de respaldo; el original, guardado.
- Almacenamiento cifrado y con acceso controlado y registrado.
- Análisis en una estación aislada.
- Conservación durante el tiempo que exijan el caso y la normativa, y destrucción segura al final.

8. Errores frecuentes

- Reinstalar el equipo «para ir más rápido», destruyendo la evidencia.
- Pasar un antivirus o reiniciar antes de capturar la memoria.
- Trabajar sobre el original.
- No calcular hashes o no anotar horas y zonas horarias.
- Investigar desde el propio equipo comprometido con una cuenta de administrador del dominio, regalando esas credenciales al atacante.
- No documentar: lo que no está escrito no ocurrió.

Para ampliar

- ISO/IEC 27037 y RFC 3227.
- UNE 71505 y UNE 71506.
- INCIBE-CERT: guía de toma de evidencias en entornos Windows.
- Documentación de FTK Imager, Volatility y Velociraptor.